Chapter route

Which cryptographic and system mechanisms provide verifiable guarantees when identities, programs, and networks can be attacked?

Prerequisites are protection, basic networking, probability, and hashing.

- Distinguish confidentiality, integrity, availability, and authentication.
- Analyze symmetric/asymmetric encryption and hashes.
- Evaluate defenses under explicit attack models.

Lin Cing
https://github.com/xinhi6716/computer-science-self-study

Assets, adversaries, and goals

Confidentiality restricts unauthorized reading; integrity restricts unauthorized modification; availability requires authorized service under stated conditions. A threat can violate a goal, a vulnerability is an exploitable weakness, and an attack is an actual attempt. Theft followed by encryption/deletion can violate several goals.

The teaching grade service protects grades, credentials, and availability. The adversary controls the network and submits arbitrary forms, but cannot modify the kernel or obtain the server's private key. If key theft is later allowed, earlier authentication conclusions no longer follow. Every guarantee depends on its adversary, trust roots, keys, and endpoint integrity.

Physical, human, OS, and network factors affect the boundary. TLS does not protect input captured by an endpoint keylogger. ACLs restrict unauthorized use without proving every valid-account action follows business rules.

Lin Cing
https://github.com/xinhi6716/computer-science-self-study

Impersonation, replay, and intermediaries

Masquerading impersonates an identity; replay resends an old valid message; a man-in-the-middle controls what both endpoints observe. A source IP is not a cryptographic identity, and an unauthenticated public key is not bound to a service.

An attacker can replay a valid MAC on transfer(A,B,100,id17) without understanding its contents. Assuming MAC unforgeability, an uncompromised key, and the stated key-holder trust model, successful verification provides computational evidence of origin from some key holder; it does not prove fresh authorization. Authenticate the session, sequence, nonce, or operation ID, and maintain receiver state. Returning an earlier result on retry requires durable deduplication atomically linked to the transaction.

Preventing new forgeries and preventing repeated execution of one authorization are distinct goals. Encryption alone establishes neither combined claim.

Authority and propagation

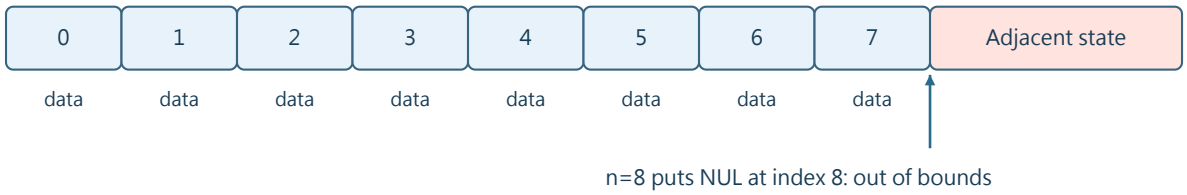
A Trojan abuses execution authority behind apparent useful behavior. A backdoor bypasses normal entry; a logic bomb triggers under a condition. Viruses infect host files/programs, while worms propagate through services/networks. Categories overlap and do not restrict viruses to one OS vendor.

An untrusted directory in PATH can substitute a namesake tool. Malicious code acquires the victim program's actual rights, not automatic root authority from its label. A compromised compiler can produce malicious output from inspected source. Executables, loaders, compilers, and update channels belong in the trust boundary.

File, boot, macro, and source viruses describe infection locations. Polymorphic, encrypted, stealth, and armored describe evasion; multipartite affects several locations. Byte signatures and behavior analysis complement one another. No signature match does not prove absence.

Buffer bounds precede control-flow claims

Abstract byte layout: the string terminator occupies a byte



Capacity 8 holds at most 7 data bytes + NUL. Binary buffers use explicit lengths.

An eight-byte buffer has indices 0–7. A C string with n data bytes requires $n+1 \leq 8$ for complete copying. At n=8 the data fits, but its NUL at index 8 overflows. Actual layout depends on ABI/compiler; this abstract figure illustrates adjacent corruption without platform addresses.

One safe contract rejects overlength input. Another explicitly truncates to k=min(n,7), copies k bytes, and sets buf[k]=0. Strncpy(...,7) alone need not append NUL. Binary data requires explicit lengths rather than strlen, with range and integer-overflow checks.

Different defenses prove different properties

Bounds/type/lifetime checks address invalid accesses. Canaries detect some overwrites before return; NX/W⊕X restrict execution from data pages; ASLR complicates address prediction; control-flow restrictions constrain targets. NX neither prevents out-of-bounds writes nor alone excludes reuse of existing executable code.

Corrupting is_admin, length, or an object pointer can violate authorization without changing return addresses. Least privilege limits a damaged component's reach but cannot replace fixing the overflow. A managed safe subset eliminates some memory errors while native/unsafe code, runtime flaws, and business policy remain boundaries. Type safety does not prove every security goal.

Worm propagation and service exposure

The 1988 Morris worm exploited service weaknesses and remote trust to seek reachable hosts. Repeated infection consumed resources; an event need not steal data to harm security.

In this discrete model, each infected host infects **at most** two distinct susceptible hosts per round, with no recovery. Thus $I_{t+1} \leq 3I_t$. Starting from $I_0=1$, the sequence 1, 3, 9, 27 holds only if every host infects exactly two distinct new hosts each round and enough susceptible hosts exist. A closed network of 100 hosts obeys $I_{t+1} \leq \min(100,3I_t)$. This is an ideal bound, not a measurement of Morris.

Scanning reveals reachable services, not necessarily vulnerabilities, and banners need not be truthful. Authorization, patching, and disabling unnecessary services reduce exposure; removing one entry does not fix input bugs elsewhere.

Resource exhaustion and defensive side effects

A teaching service has 1000 pending slots. Each incomplete handshake occupies one for 10 seconds with no early cleanup. Starting empty, accept one request every 0.01 seconds from t=0 through t=9.99 seconds: all 1000 slots are occupied before the first expires. This specified timing does not imply every arrival pattern with the same average fills the slots simultaneously.

In steady-state Little's law $L=\lambda W$, λ is the **accepted throughput** across the same observation boundary. With finite capacity and rejected requests, it need not equal offered arrival rate. If accepted throughput averages 100/s and average residence is 10 s, then average occupancy is 1000. This does not guarantee all later offers are accepted.

Legitimate demand of 80/s plus attack demand of 40/s exceeds 100/s service capacity by at least 20/s. Cookies, quotas, and delayed allocation change state costs, not upstream bandwidth. Rate limits must name their key; IP limits can penalize users sharing NAT. A password lockout can hinder guessing while allowing attackers to deny service to others. High load alone does not distinguish DDoS from a legitimate flash crowd.

Primitives and key roles

Tool	Confidentiality	Integrity/source	Creation and verification
Symmetric encryption	With a suitable scheme	Not from encryption alone	Shared-secret holders
Public-key encryption	With a suitable scheme	Does not establish sender	Anyone encrypts; private key decrypts
Hash	No	Mismatch against trusted digest	Anyone computes
MAC	No	Shared-key origin/integrity	Key holders generate/verify
Signature	No	Private-key origin/integrity	Private signs; public verifies

Correctness means $D_k(E_k(m))=m$. Security is a computational claim against specified distinguishing/forgery attacks, not logical impossibility of guessing m. Algorithms can be public; secret keys remain secret. Public keys need authenticated integrity of their identity binding.

Reused keystream algebra

For $c=m\oplus s$, $m=c\oplus s$. Let m_1=0x41, m_2=0x42, s=0xA6; c_1=0xE7, c_2=0xE4. Reuse gives $c_1\oplus c_2$=0x03=$m_1\oplus m_2$. Knowing m_1 reveals s and then m_2. This identity does not break the underlying cipher.

Block ciphers process fixed blocks; longer messages need correct modes and nonce/IV rules. AES's 128-bit block differs from 128/192/256-bit keys. DES, 3DES, RC4, WEP are historical context, not new-deployment recommendations. Use a complete analyzed confidentiality/authentication scheme. An unprotected public hash appended to ciphertext can be recomputed after tampering.

Lin Cing https://github.com/xinhi6716/computer-science-self-study

A complete small RSA computation

This number-theory example is not secure encryption. Set p=5, q=11, n=55,ϕ=40, e=3, d=27, ed=81=1+2ϕ. Public key=(55,3), private=(55,27). For m=12, 12^2 mod55=34 and 12^3 mod55=34 · 12 mod55=23.

Decrypt with square table $23^1 \to 23, 23^2 \to 34, 23^4 \to 1, 23^8 \to 1, 23^{16} \to 1$. Since 27=16+8+2+1, 23^{27} mod55=1 · 1 · 34 · 23 mod55=12. Raw RSA is deterministic and algebraically structured. Deployable encryption/signatures additionally require specified encoding/padding, key sizes, and purpose separation. These small primes provide no confidentiality.

Lin Cing
https://github.com/xinhi6716/computer-science-self-study

RSA correctness for every message

For every m∈{0,…, n−1}, ed=1+k(p−1)(q−1). Modulo p, if p divides m, both m and m^ed are 0. Otherwise Fermat gives m^(p−1)≡1, so

$$m^{ed} = m(m^{p-1})^{k(q-1)} \equiv m \pmod{p}.$$

The same branches hold modulo q. Distinct primes and CRT yield m^ed≡m modpq, including messages not coprime with n.

Euler applied only when gcd(m, n)=1 would omit valid multiples of p/q. This proves mathematical decryption correctness, not RSA hardness, chosen-ciphertext security, or side-channel resistance.

Lin Cing
https://github.com/xinhi6716/computer-science-self-study

Hashes, MACs, and signatures

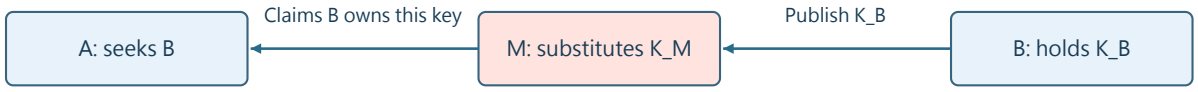
An n-bit hash has 2^n outputs, so collisions exist by the pigeonhole principle for a larger message space. Collision resistance concerns finding any distinct pair with equal digest; second-preimage resistance fixes one message first. Digest equality is computational evidence, not a theorem that messages are equal.

Anyone can replace (m, H(m)) with (m′, H(m′)); public hashes do not authenticate. MAC verifiers also know the secret, so MAC alone cannot prove to a third party that only the other participant generated a tag. Signatures use private signing and public verification, with trusted key binding, complete encoding, and key protection. They are not arbitrary encryption run backward.

HMAC is a standard keyed construction, not arbitrary H(key ∥ m). Include context, roles, session, and sequence against cross-purpose reuse.

Key distribution and substitution

Public keys need trusted identity binding, not secrecy



Without binding: A encrypts under K_M → M decrypts. Correct cipher, wrong identity.

Validate chain, name, purpose, validity, and handshake proof of private-key possession.

A seeking B receives an unauthenticated claim "B, key K". M substitutes K_M; A encrypts to M, which can decrypt although the cipher works correctly. Certificates bind service identity and key. Validate signature chains to trusted roots, target name, purpose, time, and relevant revocation policy. Certificate presence alone is insufficient.

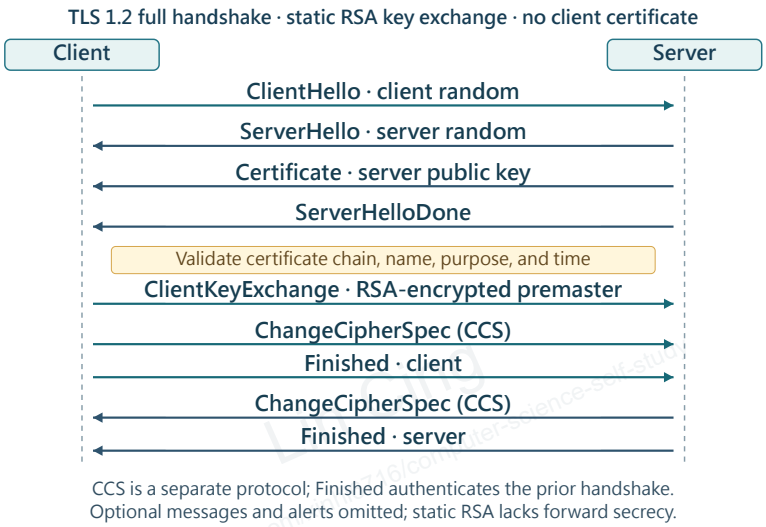
Pairwise symmetric keys for N users require N(N−1)/2 keys. Six users need 15; adding a seventh needs six more. A KDC reduces long-term secrets per user but centralizes trust. Public-key techniques reduce secret distribution without eliminating public-key authentication or private-key protection.

Endpoints determine protection scope

IPsec protects IP traffic between its network endpoints; TLS protects its session endpoints; encrypted mail can span store-and-forward hops. TLS termination at a reverse proxy exposes plaintext there and does not automatically protect proxy-to-backend traffic.

Link/network protection does not directly identify an application user. Disk encryption protects offline media, not a logged-in process authorized to read plaintext. For each layer state key holders, plaintext observers, and trusted components. Layer counts do not sum into unconditional safety.

Historical TLS 1.2 RSA handshake



Use the historical RFC 5246 full handshake with static RSA key exchange, not TLS 1.3. The client sends ClientHello(n_c); the server sends separate **ServerHello(n_s)**, **Certificate**, and **ServerHelloDone** messages. After validating chain, name, purpose, and time, the client encrypts a 48-byte premaster secret, consisting of two version bytes and 46 random bytes, under the server public key and sends it in **ClientKeyExchange**. Both derive the master secret and directional traffic keys with the PRF.

Historical TLS 1.2 RSA handshake (continued)

The client sends ChangeCipherSpec and Finished; after verification, the server sends its own ChangeCipherSpec and Finished, which the client verifies. If the figure omits ChangeCipherSpec, it remains required by the protocol; optional messages such as client certificates depend on the selected case. Finished authenticates the preceding handshake transcript. The certificate signature alone does not prove the current peer possesses the private key. Authentication also requires correct name binding and endpoint assumptions; a live relay remains possible.

Static RSA key exchange lacks forward secrecy: later server private-key compromise and a recorded ClientKeyExchange can expose the old premaster even after traffic keys are deleted. SSL 3 and TLS are not synonyms; RFC 7568 prohibited SSL 3 in 2015. This is a historical teaching model.

Lin Cing
https://github.com/xinhi6716/computer-science-self-study

Freshness and atomic nonce consumption

Server issues nonce 42 with pending[42]=(U, expiry). Client returns MAC_k("login" ∥ U ∥ n ∥ serverID). Receiver validates tag and pending/expiry, and atomically changes n to used. First succeeds; an identical valid replay fails because n is used.

MAC integrity cannot reject a copied tag without freshness state. Consume only after successful verification and make checking/consumption atomic; otherwise two threads can both observe pending. Random nonces need entropy/nonreuse; counters need restart persistence or a new session. Payments additionally link consumption and business effects transactionally or through recoverable deduplication, preventing crash-induced loss/repetition.

Lin Cing
https://github.com/xinhi6716/computer-science-self-study

Credentials and sessions

Knowledge, possession, and inherence are distinct factor types. Two passwords remain one type; MFA uses at least two types, not necessarily all three. A stolen authenticated session token can bypass the original factors, so session protection, invalidation, and reauthentication matter.

An abstract verifier record is {user, salt, cost, KDF(password, salt, cost)}. Login recomputes and compares. Public salt prevents sharing one precomputed dictionary across records, not guessing one record or mathematically eliminating collisions. Stolen verifiers still permit offline guesses and need access protection. Historical eight-character UNIX limits belong to particular old schemes, not every UNIX or a modern policy.

Lin Cing
https://github.com/xinhi6716/computer-science-self-study

Guess spaces and computation

Uniform random four-digit decimal PINs, including 0000, have 10000 possibilities. Distinct unbiased guesses have mean rank 5000.5. At 1 ms/guess, mean time is 5.0005 s. This is not every four-character password or a human-biased dictionary.

For 1000 distinct salts and 100000 candidates, testing every record costs about $1000 \cdot 100000$ KDFs rather than 100000 reusable hashes. At 5 ms each, one serial work unit takes $500000\ \text{s} \approx 5.79$ days. Parallel resources, memory constraints, and prior distributions change actual cost. Online limits do not constrain stolen-verifier offline work; lockouts can become DoS.

Lin Cing
https://github.com/xinhi6716/computer-science-self-study

OTP and biometric errors

OTP/challenge-response adds freshness. One-time use is a receiver acceptance rule, not merely changing displayed digits. TOTP windows need explicit replay/used-code handling and remain vulnerable to real-time phishing relay.

Biometric thresholds trade false acceptance and rejection. FAR uses impostor attempts; FRR uses genuine attempts. With 100000 impostor attempts, FAR 0.1% means 100 false accepts; with 10000 genuine attempts, FRR 2% means 200 false rejects. Threshold, population, device, and environment change estimates.

Biometrics are not freely replaceable secrets. Templates, liveness/attack detection, lost devices, and fallback policy affect security. Factors sharing a compromised endpoint/recovery path can fail together; multiplying failure probabilities requires independence.

Policy, assessment, and layers

Policy specifies assets, operations, responsibilities, and response. Assessment checks configuration, code, and exposure; authorized penetration tests examine exploit paths. A passed scan supports its time/scope/tools/known checks, not universal absence of vulnerabilities.

Layers sharing a stolen key or bad identity header have common failure. Patching, least privilege, memory/input safety, segmentation, authentication, monitoring, and recovery affect different probabilities/damage. Name the path each blocks.

An original model has loss 100000 currency units and annual probability 0.02, expected loss 2000/year. Reducing probability to 0.005 leaves 500, saving expected 1500/year. Tail disasters, correlated events, and regulatory obligations are absent and can still determine policy.

IDS/IPS and base rates

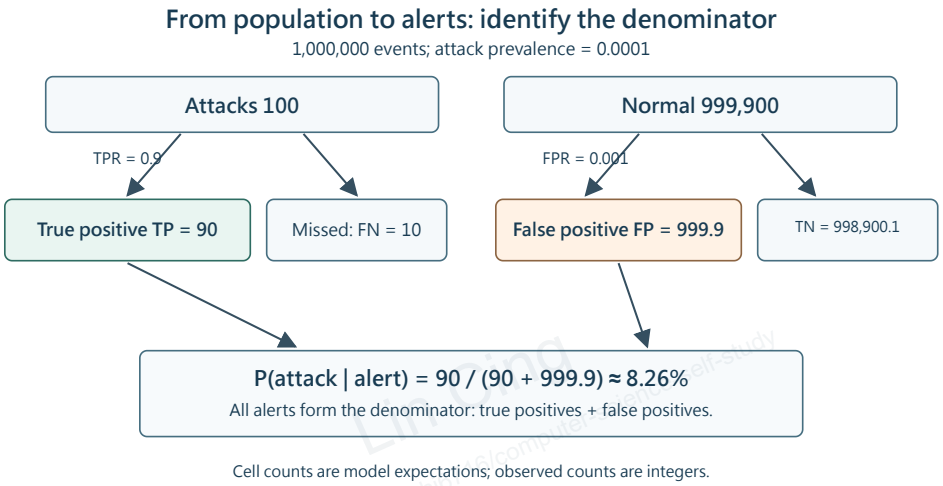
Signatures detect encoded patterns; anomaly detectors find baseline deviations. Unknown attacks need not all evade signatures; anomalous events need not be malicious. IDS usually alerts; IPS can block, directly risking availability on errors.

Of 1000000 events, 100 are attacks. TPR=0.9 gives TP=90, FN=10. Normal=999900 with FPR=0.001 gives expected FP=999.9, TN=998900.1. Alarm precision=90/(90+999.9)≈8.26%, not 90%. TPR divides by attacks; precision divides by alarms.

$$\text{precision} = \frac{\pi\, TPR}{\pi\, TPR + (1-\pi) FPR}.$$

At π=0.0001, TPR=0.9, precision≥0.5 requires FPR≤0.000090009…. Baseline contamination, drift, and correlated-event aggregation affect estimation. Development data cannot be relabeled independent acceptance data.

IDS alerts: build the denominator first



The model yields 90 expected true positives and 999.9 expected false positives. The population conditional probability of attack given an alert is about 8.26%. Fractional cell counts are expectations, not observed event counts.

Integrity monitoring and recovery

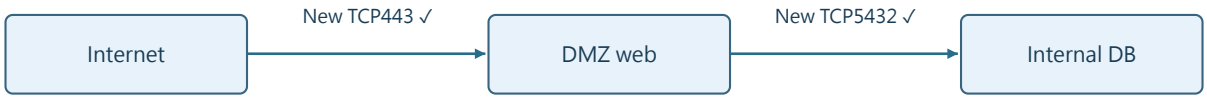
Compare content/metadata with a trusted baseline. Compromising both checker and baseline removes that trust root. Hash comparisons require suitable collision resistance and protected original digests; equality is not absolute identity proof.

Tripwire-style monitoring distinguishes authorized updates from unexpected changes. Changing logs still need protected remote/append-only records and correlation. A honeypot must not become an unrestricted internal attack relay. Antivirus signatures, behavior, and sandboxes have limited coverage; a clean scan does not prove supply-chain innocence.

Response includes isolation, evidence preservation, root-cause repair, trusted-backup recovery, and credential rotation. Audit subject, object, action, decision, time, and correlation ID while protecting log integrity/availability.

Allowed connections before filter rules

Zones are not full trust: allow only specified directions/services



Deny new Internet → DB and web → DB22. Validate return packets against existing state.

Compromised web still reaches DB5432. DB needs authentication and minimum query authority.

Allow new Internet→DMZ web TCP443, web→internal DB TCP5432, and internal→Internet TCP443. Deny other new connections. Permit returns only if they match existing state. DMZ does not gain all internal access. A compromised web server can abuse its required DB5432 path, requiring database authentication/query authorization.

Stateless filters inspect headers; stateful filters track connections; proxies terminate/understand applications; host firewalls govern local ingress/egress. Without TLS termination, packet filters cannot inspect encrypted application meaning. Allowing 443 does not make its payload safe.

Rule order and limits

Rules2–4 implement the three new-connection paths: Internet→web, web→DB, and internal→Internet. Rule1 admits subsequent packets in either direction of an existing allowed connection. New TCP service rules match destination ports.

Order	Match	Action
1	Packet matching an existing allowed connection state, either direction	Allow
2	New TCP, Internet→DMZ web, destination443	Allow
3	New TCP, DMZ web→internal DB, destination5432	Allow
4	New TCP, internal→Internet, destination443	Allow
5	All remaining packets	Deny

Rule order and limits (continued)

Packet	First matching rule	Result
New Internet→web TCP443	2	Allow
New web→DB TCP5432	3	Allow
New internal→Internet TCP443	4	Allow
New Internet→DB TCP5432	5	Deny
New web→DB TCP22	5	Deny
DB→web return actually matching existing state	1	Allow
web→DB subsequent data in an existing allowed connection	1	Allow

Match source/destination addresses, zones, destination port, direction, and state. An ACK bit or a claimed established status without a matching state-table entry does not satisfy rule1.

Putting deny-all first makes later permits unreachable. Actual products have specific chain/priority semantics. Firewalls do not repair allowed-protocol bugs, authenticate hosts merely by IP, or restore saturated upstream bandwidth through local dropping. Tunnels, egress, and dependencies such as DNS need explicit policies.

Historical TCSEC assurance

The DoD Orange Book is not a universal modern product score. D fails higher classes. C1/C2 emphasize discretionary access/accountability; C2 adds individual control, auditing, and object reuse. B1–B3 add mandatory labels and stronger structure/analysis. A 1 adds formal design/verification and development assurance to B3 functionality.

B2 covert-channel requirements identify/analyze paths bypassing intended information flow, rather than support exfiltration. The TCB includes hardware, software, and firmware enforcing policy. If an outside component can break that policy, the boundary is wrong.

Evaluation applies to its version, configuration, policy, and environment. A 1 does not eliminate business errors/all attacks or automatically certify later versions. Formal proofs depend on their models, assumptions, and specifications.

Lin Cing
https://github.com/xinhi6716/computer-science-self-study

Tokens and security descriptors

The historical primary token holds user/group SIDs and privileges. An impersonating server thread can use client context. Object descriptors contain owner, DACL, SACL; DACL grants/denies, while SACL can hold auditing/mandatory labels. Existing handles have granted access; not every operation reruns an identical open check.

For ordinary specific rights only, excluding owner/privilege exceptions, restricted-token checks, and object ACEs, set remaining=requested. In ACE order, matching deny intersecting remaining rejects. Matching allow removes granted bits. Empty remaining succeeds; reaching the end with bits left denies. This is not a universal union-all-allows-minus-all-denies algorithm.

Inheritance, copy/move, and propagation to existing objects depend on filesystem/API options. Inspect the final descriptor at creation. Parent ACL changes do not universally rewrite existing handles.

Lin Cing
https://github.com/xinhi6716/computer-science-self-study

DACL mask trace

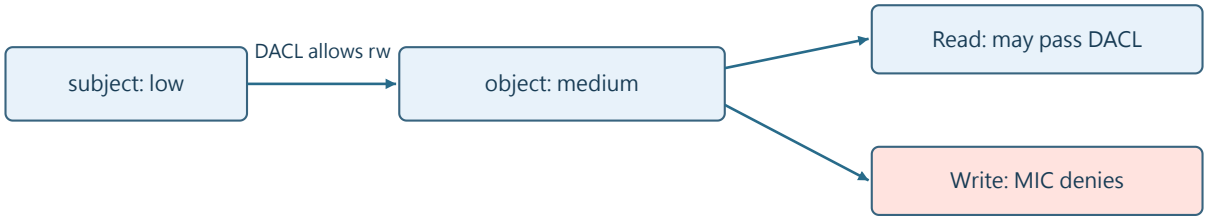
Request={r, w}; token U includes enabled Students. DACL=[deny(Students, w), allow(U, rw)]. Initially remaining={r, w}; the first intersects w and immediately denies. Without Students, skip it and allow U removes both bits, succeeding.

Deliberately placing allow(U, rw) first satisfies the request before reaching later deny. Deny does not override every allow regardless of order. Preferred canonical order places relevant explicit denies before allows; inheritance needs more ordering rules.

NULL DACL is absent and allows in this ordinary model. Empty DACL exists with no ACEs and grants nothing. Neither bypasses mandatory policy or special privilege rules.

MIC and UAC

One DACL grant; mandatory policy still distinguishes read/write



Assume NO_WRITE_UP only. Adding NO_READ_UP also denies the read branch.

Low-integrity subject, medium object, DACL allows r, w. With only NO_WRITE_UP, write fails while read can pass DACL/other checks. NO_READ_UP additionally denies read. Integrity primarily resists low-trust modification; it is not a full confidentiality-clearance model.

Windows 7 UAC can run an administrator's ordinary applications under a filtered medium token; controlled elevation obtains the corresponding higher token. A prompt neither creates rights the user never held nor identifies malicious programs.

Composing security arguments

Authentication binds credentials/keys to subjects; authorization limits operations; cryptographic schemes protect messages; freshness/receiver state prevent replay; transaction/recovery connects authorization to a recoverable effect. One layer cannot supply another's missing premise.

Valid MAC replay still needs denial. TLS ending at a compromised proxy does not guarantee end-to-end secrecy. MIC can reject DACL-authorized writes. NX does not prevent authorization-data corruption. State premises, failure consequences, and observable checks.

Lin Cing
https://github.com/xinhi6716/computer-science-self-study

Proofs, examples, and configuration evidence

Fermat/CRT proves RSA correctness for all messages; a modular-power table checks one. Keystream leakage follows an XOR identity. Bayes connects IDS denominators; TPR alone is not precision. Historical cases retain versions, endpoints, and omissions. One replay test, DACL trace, or scan supports that observation without replacing general transition/threat-model reasoning.

References and attribution

Lin Cing, handwritten operating systems notes. Silberschatz et al., Operating System Concepts, 9th ed., Ch. 15. RFC 5246. RFC 7568. Microsoft: DACL. Microsoft: MIC.

Original educational synthesis by Lin Cing, licensed under CC BY 4.0.

https://github.com/xinhi6716/computer-science-self-study